

정보보호 개요



학습내용

- 정보보호 개념
- 정보보호 활동 프로세스

학습목표

- 정보보호에 대한 **기본개념**을 설명할 수 있다.
- 정보보호의 목적을 알고 **정보보호의 중요성**을 설명할 수 있다.
- 정보보호 활동의 **전체적인 과정**을 이해하고 적용할 수 있다.

1. 정보보호의 의미

1) 정보의 의미

- 관찰이나 측정을 통하여 수집한 자료를 실제 문제에 도움될 수 있도록 정리한 지식 또는 그 자료
- 데이터(현실 세계로부터 단순한 관찰이나 측정을 통해서 수집한 사실이나 값)를 처리·가공한 것이 정보(어떤 상황에 관한 의사 결정을 할 수 있게 하는 지식으로서 데이터의 유효한 해석이나 데이터 상호간의 관계)임
- 특정 목적을 위하여 광(光) 또는 전자적 방식으로 처리되어 부호, 문자, 음성 및 영상 등으로 표현된 모든 종류의 자료 또는 지식 (국가정보화기본법 제3조)

2) 정보보호의 정의

- 정보의 수집, 가공, 저장, 검색, 송신, 수신 중 발생할 수 있는 정보의 훼손, 변조, 유출 등을 방지하기 위한 관리적·기술적 수단을 마련하는 것 (국가정보화기본법 제3조)
- 무결성, 기밀성, 가용성을 제공하기 위하여 정보 및 정보시스템이 허가되지 않은 접근, 사용, 폭로, 전복, 수정 또는 파괴되는 것으로부터 보호하는 것(미국의 연방정보보호관리법)
- 정보보호 활동의 수행
 - ✓ 예산 및 인력 등 많은 분야에서 지출 및 노력이 필요
 - ✓ 보안이 보장되지 않는 서비스는 사용 불가

2. 정보보호의 필요성

1) 정보보호의 필요성

(1) 비즈니스 패러다임 및 IT 환경의 변화

- 기업 비즈니스에 인터넷은 필수적인 요건
- 스마트 폰, 스마트 와치 등 모바일 디바이스 이용 확대

(2) 기업의 사회적 책임 요구 증대

- 정보보호 사고는 기업의 이미지 훼손 및 주가 하락 등을 유발
- 개인정보를 수집·보관·이용하는 기업에 대한 책임 강화

(3) 정보보호 사고 발생 가능성 증대

- 언론·금융사 전산망 마비 등 사이버 공격의 지속적 증가
- 기업의 정보 자산은 해커들의 공격 대상이 됨
- 기업의 정보보호 예산 및 인력은 여전히 부족한 상태

(4) 공격 기술의 다양화·악성화

- | | |
|-------------|-----------|
| ▪ 시스템 마비 | ▪ 웜 |
| ▪ 네트워크 마비 | ▪ 스파이웨어 |
| ▪ 서비스 방해 공격 | ▪ 악성루머 유포 |
| ▪ 크래킹 | ▪ 스팸 메일 |
| ▪ 바이러스 | ▪ 피싱 |

2. 정보보호의 필요성

2) 해킹사고 현황 및 특징

(1) 해킹 사고 신고

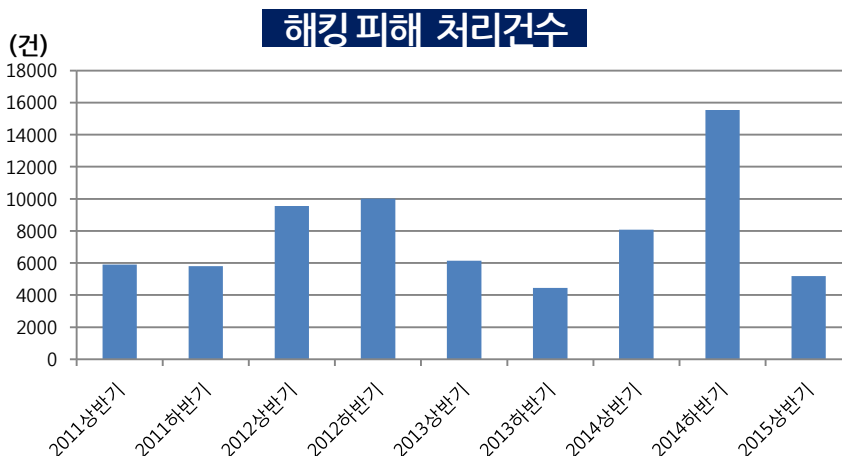
- 한국인터넷진흥원(KISA) : 개인 및 민간업체
- 국정원(NIS) : 공공기관
- 경찰청(사이버테러 대응센터) : 해킹범죄 접수 및 처리 담당

(2) 해킹의 주요 특징

- 홈페이지 해킹도 단순 과시용에서 금전적인 이익을 목적으로 변화하고 있음
- 피싱 사고의 지속적 발생
- 새로운 유형의 침해사고 발생

→ 새로운 새로운 형태의 인터넷 융합 서비스가 활성화됨에 따라 이를 대상으로 하는 해킹 공격의 출현 가능성이 높아졌기 때문!

(3) 연도별 해킹 사고



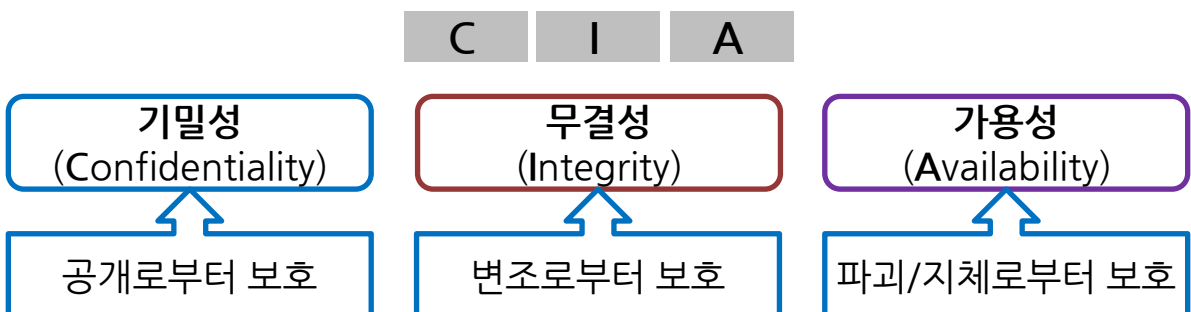
[출처: e-나라지표]

2. 정보보호의 필요성

3) 사이버 공격의 특성

- 사이버공격의 **지능화, 다양화, 복합화 및 자동화**
- 사회공학적 기법과 다양한 기술적 방법이 결합된 사이버공격 도구 출현
- 다중 이용 매체를 통해 여타 시스템으로 신속하게 **전파**
- 백신, IDS/IPS 등 정보보호시스템을 우회하거나 무력화하는 공격 출현
- 보안취약점이 공개되고 이에 대한 **패치가 나오기 전(Zeroday)** 공격 시도
- **역연결(Reverse connection)**을 이용해 원격 제어하는 악성코드 급증(탐지곤란)
- 특정 대상을 지속적으로 공격하는 **지능형 타깃 위협(APT)**
- 경제적, 정치적 목적을 달성코자 하는 **DDoS 공격** 보편화(대규모 로봇망 구축)

3. 정보보호 목적



3. 정보보호 목적

1) 정보보호의 주요 목표

(1) 기밀성

- **정당한 사용자**만 데이터에 **접근**할 수 있도록 **비밀** 유지
- 허가 받지 않은 비인가자에게 정보가 노출되지 않도록 보장
- 정보의 소유자가 원하는 대로 정보 비밀 유지
- 기밀성 보장 수단 : 접근통제, 암호화 등

(2) 무결성

- 승인된 주체 및 허가된 방법에 의해서만 변경 가능하게 하는 것
- 비인가자에 의한 정보의 **변경, 삭제, 생성**을 **방지**하여 정보의 정확성과 완전성 보장
- 무결성 통제 수단 : 물리적 통제, 접근통제, 인증 등

(3) 가용성

- 정보 또는 정보 시스템이 **정당한 사용자가 원할 때**에 정상적으로 제공되어야 함
- 사고 및 재앙이 발생하더라도 신속하고 안전하게 복구되어야 함

(4) 인증

- 네트워크를 경유해서 컴퓨터에 접속해 오는 사용자가 허가 받은 사용자인지를 확인하는 것

(5) 부인방지

- 메시지의 송수신 및 교환 후/ 통신이나 처리 후에 그 사실을 증명함으로써 사실 부인을 방지하는 것

3. 정보보호 목적

2) 공격 위험의 원인과 정보보호 목적과의 관계

(1) 실수 및 오류 (연관 : 무결성, 가용성)

- 내부직원의 실수 및 간헐적인 시스템 오류
→ 데이터 변경 및 삭제 발생
- 오작동 시 시스템 다운 등의 가용성 저해
- 발생 빈도가 가장 높음

(2) 공격자 (연관 : 기밀성)

- 일반적인 해커
- 스릴과 과시를 위하여 네트워크에 침입함
- 시스템을 해킹하여 정보 유출함

(3) 범죄집단 (연관 : 기밀성)

- 금전적 이득을 위하여 시스템 공격
- 스팸/피싱/스파이웨어/멀웨어를 이용하여 신원 획득, 온라인 사기를 벌임 → 개인정보의 유출 등 피해 발생

(4) 악의적 내부자 (연관 : 무결성, 기밀성)

- 시스템 접근 권한을 가진 내부자
- 가장 심각한 요인

(5) 피셔 (연관 : 기밀성)

- 개인 신원정보를 획득하기 위한 피싱을 실행하는 사람/조직
- 스파이웨어/멀웨어와 같은 악성코드 유포

3. 정보보호 목적

2) 공격 위험의 원인과 정보보호 목적과의 관계

(6) 스팸 발송자 (연관 : 가용성)

- e-메일을 통하여 제품의 판매, 피싱의 실행, DoS 같은 공격을 시도하는 사람/조직
- 서비스/네트워크 장애 유발

(7) 악성프로그램 제작자 (연관 : 기밀성)

- 악의적인 목적으로 공격을 수행하는 스파이웨어/멀웨어를 제작하여 배포하는 사람/집단
- 스파이웨어 같은 악성프로그램으로 인해 아이디, 패스워드, 은행 계좌번호 및 비밀번호 등의 정보들이 유출

(8) 사이버테러범 (연관 : 기밀성, 무결성, 가용성)

- 사회에 혼란을 주기 위한 테러의 행위로 사이버공격을 하는 주체

(9) 해외 정보기관 (연관 : 기밀성)

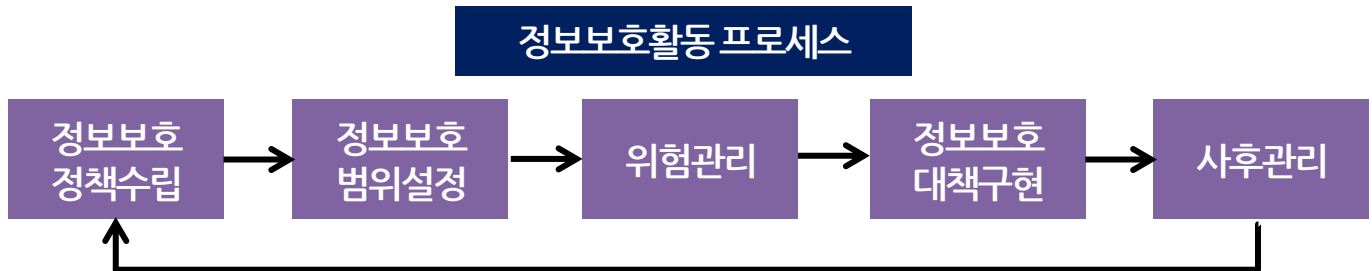
- 정보수집과 스파이활동 등의 목적으로 사이버공격 툴 사용
- 정보기관에 국가의 중요 정보들이 노출되는 해킹 피해

정보보호 활동 프로세스

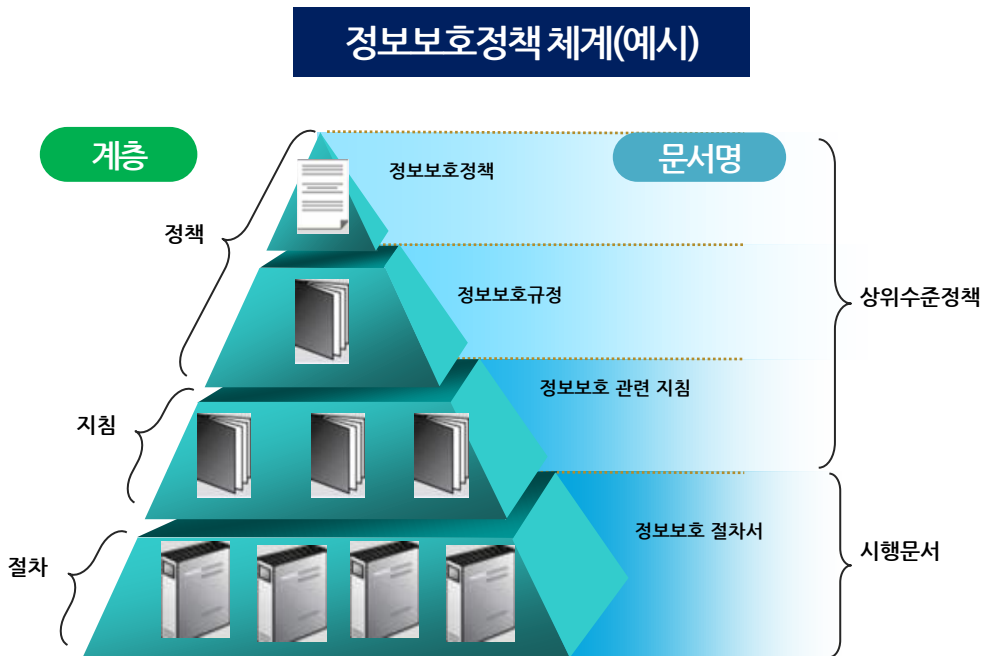
1. 정보보호 정책수립

1) 정보보호 관리체계 인증 제도

- 정보보호 활동 : 회사의 중요 자산들을 안전하게 보호하기 위한 활동



- 조직 전반에 걸친 상위 수준의 정보보호정책 수립
- 정보보호를 수행하기 위한 조직 내 각 부문의 책임 설정



[출처: 정보보호 관리체계(ISMS) 인증 제도 안내서(개정안)]

1. 정보보호 정책수립

2) 정보보호 정책에 포함되어야 할 내용

- **목적** : 중요한 정보자산이 무엇인지 식별하여 선언
- **대상 범위** : 정보자산, 인적·물적 자원
- **내용** : 간단 명료하게 작성, 조직의 최상위 정보보호 활동에 대한 기본 방향 제시
- **책임** : 정책을 수행하기 위한 기본 책임사항 정의
- **문서의 승인** : 조직의 최고책임자가 정책을 승인하고 지원의지를 알려야 함

3) 정보보호 지침·절차

(1) 정보보호 지침

- 정보보호에 있어서 지켜야 할 규칙을 규정함
- 예 : 문서보안관리 지침, 외주용역관리 지침, 정보자산관리 지침, 정보시스템관리 지침, 네트워크관리 지침 등

(2) 정보보호 절차

- 규칙을 지키기 위해서 구체적인 순서 등을 규정함
- 문서를 사용하는 대상이 누구인가를 고려해야 함



2. 정보보호 범위설정

1) 정보보호 범위설정 의미

(1) 정보보호 범위설정

- 조직, 자산, 서비스 및 중요 업무를 고려
- 설정된 범위에 대해 위험관리 및 그에 따른 정보보호 대책 구현

(2) 정보보호 범위

- 정보보호 관리체계의 범위 내 서비스, 업무, 조직, 정보시스템, 설비 등을 명확하게 정의하여 설명해야 함
- **특정 영역에만 해당되는 경우** → 범위 영역 경계를 식별하여 문서화
- **범위가 일부일 경우** → 전체사업 대비 해당 범위를 명확하게 식별할 수 있도록 함

2) 정보보호 범위설정 예시

- 정보보호의 범위 설정 시 전체 조직도, 정보보호 조직도, 정보보호 조직별 역할, 조직 운영상의 특징 등을 고려
- 구체적인 예 : 시스템 구성도, 자산 목록, 규정 및 지침 목록
- 자산 목록(가장 핵심) → 서버, 네트워크, 정보보호시스템, 업무용 PC, S/W, 정보 등 보호해야 할 대상들이 명확하게 식별되어야 함



2. 정보보호 범위설정

3) 자산식별 및 문서화

- 정보자산의 식별 : 현재 보유중인 모든 자산 중 보호해야 할 대상을 정의하는 것
- 새로 도입되는 자산 : 개별적으로 식별하여 관리대상에 포함

3. 위험관리

1) 위험관리의 방법

- 조직의 정보보호 전 영역에 대한 위험식별 및 평가가 가능하도록 위험관리 방법을 선정해야 함
- 위험관리 방법 및 절차에 따라 위험관리 대상, 위험관리 수행 인력 등이 포함된 위험관리계획을 매년 수립하고 이행함
- 위험관리 대상에는 정보보호 관리체계 인증범위 내 핵심자산 및 서비스가 누락 없이 포함되어야 함

2) 위험관리방법 선정

- 위험관리 방법론 : 국내외 표준에 따라 수행하고, 조직의 특성에 맞게 적절한 방법론을 선택하여 수행함
- 위험관리 방법 자체의 적절설도 주기적으로 검토를 수행함



3. 위험관리

3) 위험관리계획 수립

- 조직의 정보보호정책에 따라 위험관리를 수행할 조직을 지정
- 각 조직의 역할과 책임, 기본적인 절차 등을 문서화
- 위험분석·평가 수행 조직 : 전담조직, 관련 대상 부서의 책임자, 필요 시 외부 전문가가 포함되기도 함

4) 위험식별 및 평가

- 자산 중 서버, 네트워크, 정보보호시스템, 업무용 PC 등 장비에 대해 위험을 평가하기 위해서는 기술적인 위협과 취약성을 분석하는 작업을 수행해야 함

5) 수용 가능한 위험 수준 설정

- 수용 가능한 위험 수준(DoA) : 측정된 위험들에 대해서 위험을 감수하겠다는 기준을 정하는 것
- 위험 감소를 위해 조직, 예산, 구현 가능성 등을 종합적으로 고려하여 단기, 중장기 등으로 정보보호대책을 수립하여 위험을 관리해야 함
- 매년 위험관리를 통해 지속적인 관리가 가능하도록 문서화 수행

4. 정보보호대책 구현

1) 정보보호대책 선정

(1) 정보보호대책 선정

- 위험감소가 필요한 항목들의 위험들을 수용 가능한 수준으로 감소시키기 위함
- 기술, 재정, 적용되는 법제도, 시간, 조직문화 등 제약조건 고려

(2) 위험관리 전략 고려사항

- 위험 수용 : 위험을 받아들이고 비용을 감수함
- 위험 감소 : 위험을 감소시킬 수 있는 대책을 채택하여 구현함
- 위험 회피 : 위험이 존재하는 프로세스나 사업을 포기함
- 위험 전가 : 잠재적 비용을 제3자에게 이전하거나 할당함

2) 정보보호대책 구현

(1) 정보보호대책 구현

- 정보보호대책 선정에서 정의된 일정 계획과 우선순위에 따라 구현

(2) 구현된 정보보호대책 검토

- 계획대로 프로젝트가 진행되었는지의 여부
- 프로젝트가 목적을 달성하였는지의 여부



5. 사후관리

1) 법적 요구사항 준수 검토

- 처음 수립한 정보보호정책이 **법적인 요구사항을 만족하는지** 주기적 검토 필요
- 수립된 정보보호정책을 **최신 및 기존 법률, 시행령, 시행규칙, 고시의 제·개정**에 따라 관련 정책 내용을 신속히 보완
- 매월, 분기, 반기 등 년 1회 이상 주기적 또는 수시로 **조직이 준수해야 하는 정보보호 관련 법률**의 제·개정 사항 파악

2) 운영현황 관리

- 정보보호정책이 효과적으로 달성되고 있는지를 확인하기 위하여 주요한 수행업무들을 목록화하여 문서화하고, 그 운영현황과 이행 여부를 지속적으로 관리하는 것이 필요
- 보안위반 사건 및 사고 발생 시에 적시 발견 및 대응 가능하게 함

핵심요약

1. 정보보호 개념

1) 정보보호

- 정보의 수집, 가공, 저장, 검색, 송신, 수신 중 발생할 수 있는 정보의 훼손, 변조, 유출 등을 방지하기 위한 관리적·기술적 수단을 마련하는 것

2) 정보보호의 필요성

- 비즈니스 패러다임 및 IT 환경의 변화, 기업의 사회적 책임 요구 증대, 정보보호 사고 발생 가능성 증대, 공격 기술의 다양화, 악성화

3) 정보보호 목적

- 기밀성, 무결성, 가용성

2. 정보보호 활동 프로세스

1) 정보보호 활동 프로세스

- 정보보호 정책수립 → 정보보호 범위설정 → 위험관리 → 정보보호 대책 구현 → 사후관리

2) 위험관리와 보안위협 탐지 관계

- 보안위협 탐지는 정보보호 활동 중 위험관리의 일부 영역